

Ejercicios: Auditoría básica de páginas web

Objetivo: Analizar vulnerabilidades comunes en una página web usando herramientas incluidas en Kali Linux.

Material necesario

- Kali Linux.
- Una página web de pruebas (puede ser una aplicación vulnerable en local, como DVWA o WebGoat, o un sitio autorizado para prácticas, como **testphp.vulnweb.com**).

Pasos

1. Haz un escaneo con **Nikto** para identificar configuraciones inseguras y vulnerabilidades:

nikto -h <http://testphp.vulnweb.com>

```
(kali@kali)~/var/www/html/DVWA/config
$ nikto -h http://localhost/DVWA/

- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 80
+ Start Time: 2026-01-25 12:04:41 (GMT-5)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (Use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ 7850 requests: 0 error(s) and 16 item(s) reported on remote host
+ End Time: 2026-01-25 12:04:54 (GMT-5) (13 seconds)

+ 1 host(s) tested
```

2. Analiza con **WhatWeb** qué tecnologías usa el sitio (servidor, CMS, etc.):

whatweb <http://testphp.vulnweb.com>

```
(kali@kali)~/var/www/html/DVWA/config
$ whatweb http://localhost/DVWA/

http://localhost/DVWA/ [302 Found] Apache[2.4.65], Cookies[PHPSESSID,security], HTTPServer[Debian Linux][Apache/2.4.65 (Debian)], HttpOnly[PHPSESSID,security], IP[:1], RedirectLocation[login.php]
http://localhost/DVWA/login.php [200 OK] Apache[2.4.65], Cookies[PHPSESSID,security], DVWA, HTML5, HTTPServer[Debian Linux][Apache/2.4.65 (Debian)], HttpOnly[PHPSESSID,security], IP[:1], PHP, PasswordField[password], Title[Login :: De
an Vulnerable Web Application (DVWA)]
```

- Opcional: Haz un escaneo con **sqlmap** para comprobar si un formulario es vulnerable a inyección SQL:

sqlmap -u

"http://testphp.vulnweb.com/artists.php?artist=1" --batch

```
kali@kali:~/var/www/html/DVWA/config$ sqlmap -u "http://localhost/DVWA/" --batch

{1.9.9stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 12:06:26 /2026-01-25/

[12:06:26] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/article.php?id=1') and without providing any POST parameters through option '--data'
do you want to try URI injections in the target URL itself? [Y/n/q] Y
[12:06:26] [INFO] testing connection to the target URL
got a 302 redirect to 'http://localhost/DVWA/login.php'. Do you want to follow? [Y/n] Y
you have not declared cookie(s), while server wants to set its own ('security-impossible;PHPSESSID=c88c7b0b0bf...5923f387e7'). Do you want to use those [Y/n] Y
[12:06:26] [INFO] checking if the target is protected by some kind of WAF/IPS
[12:06:26] [INFO] testing if the target URL content is stable
[12:06:26] [WARNING] URI parameter 'id*' does not appear to be dynamic
[12:06:26] [WARNING] heuristic (basic) test shows that URI parameter 'id*' might not be injectable
[12:06:26] [INFO] testing for SQL injection on URI parameter 'id*'
[12:06:26] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[12:06:26] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[12:06:26] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[12:06:26] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[12:06:26] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[12:06:26] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[12:06:26] [INFO] testing 'Generic inline queries'
[12:06:26] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[12:06:26] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[12:06:26] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[12:06:27] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[12:06:27] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[12:06:27] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[12:06:27] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[12:06:27] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[12:06:27] [WARNING] URI parameter 'id*' does not seem to be injectable
[12:06:27] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involve d (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'
[12:06:27] [WARNING] HTTP error codes detected during run:
404 (Not Found) - 72 times

[*] ending @ 12:06:27 /2026-01-25/
```

si queremos listar las bases de datos sería:

sqlmap -u

"http://testphp.vulnweb.com/artists.php?artist=1" --dbs

```
kali@kali:~/var/www/html/DVWA/config$ sqlmap -u "http://localhost/DVWA/" --dbs

{1.9.9stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 12:06:47 /2026-01-25/

[12:06:47] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/article.php?id=1') and without providing any POST parameters through option '--data'
do you want to try URI injections in the target URL itself? [Y/n/q] Y
[12:06:47] [INFO] testing connection to the target URL
got a 302 redirect to 'http://localhost/DVWA/login.php'. Do you want to follow? [Y/n] Y
you have not declared cookie(s), while server wants to set its own ('security-impossible;PHPSESSID=634da75e95b...1d22603bd'). Do you want to use those [Y/n] Y
[12:06:47] [INFO] checking if the target URL content is stable
[12:06:47] [WARNING] URI parameter 'id*' does not appear to be dynamic
[12:06:47] [WARNING] heuristic (basic) test shows that URI parameter 'id*' might not be injectable
[12:06:47] [INFO] testing for SQL injection on URI parameter 'id*'
[12:06:47] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[12:06:47] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[12:06:47] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[12:06:47] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[12:06:47] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[12:06:47] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[12:06:47] [INFO] testing 'Generic inline queries'
[12:06:47] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[12:06:47] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[12:06:47] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[12:06:47] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[12:06:47] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[12:06:47] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[12:06:47] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[12:06:47] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[12:06:47] [WARNING] URI parameter 'id*' does not seem to be injectable
[12:06:47] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involve d (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'
[12:06:47] [WARNING] HTTP error codes detected during run:
404 (Not Found) - 72 times

[*] ending @ 12:06:59 /2026-01-25/
```

Resultado esperado

- Informe de posibles vulnerabilidades (cabeceras inseguras, directorios ocultos, configuraciones por defecto).
- Identificación de tecnologías utilizadas en la web (PHP, Apache, etc.).
- Detección (si la hay) de parámetros vulnerables a inyección SQL.